

The European Union flag, featuring a circle of twelve gold stars on a blue background, is positioned on the left side of the slide.

Supervisory Ecosystem: ENISA, EBA, ESMA, EIOPA, NIS2 Authorities

COORDINATING CYBERSECURITY AND FINANCIAL OVERSIGHT ACROSS
THE EUROPEAN REGULATORY LANDSCAPE



Introduction to the Supervisory Ecosystem

Supervisory ecosystem ensures digital resilience and cybersecurity in Europe

- Oversight impacts trust, security, and operational continuity

Understanding authorities is key to compliance and strategic advantage

- Authorities' interplay shapes regulatory landscape

Applies to compliance professionals, IT leaders, and risk managers

- Knowledge supports organizational maturity and advantage

Oversight extends beyond legal obligation to business opportunity

- Compliance is a pathway to strategic growth





Overview of Key EU Authorities

EU ecosystem anchored by ENISA, EBA, ESMA, EIOPA, national NIS2 authorities

- Each body has a distinctive, interwoven mission

Regulations and oversight enable financial system resilience

- Essential services depend on complex supervisory networks

Authorities collectively guide cyber risk identification and reporting

- Standards impact organizational cyber risk approaches

National NIS2 authorities complete the ecosystem structure

- Their role complements EU agencies' mandates

ENISA – The Cybersecurity Nerve Center

ENISA provides EU-wide cybersecurity expertise and best practices

- Acts as both lighthouse for threats and bridge for collaboration

Connects national authorities, businesses, policymakers

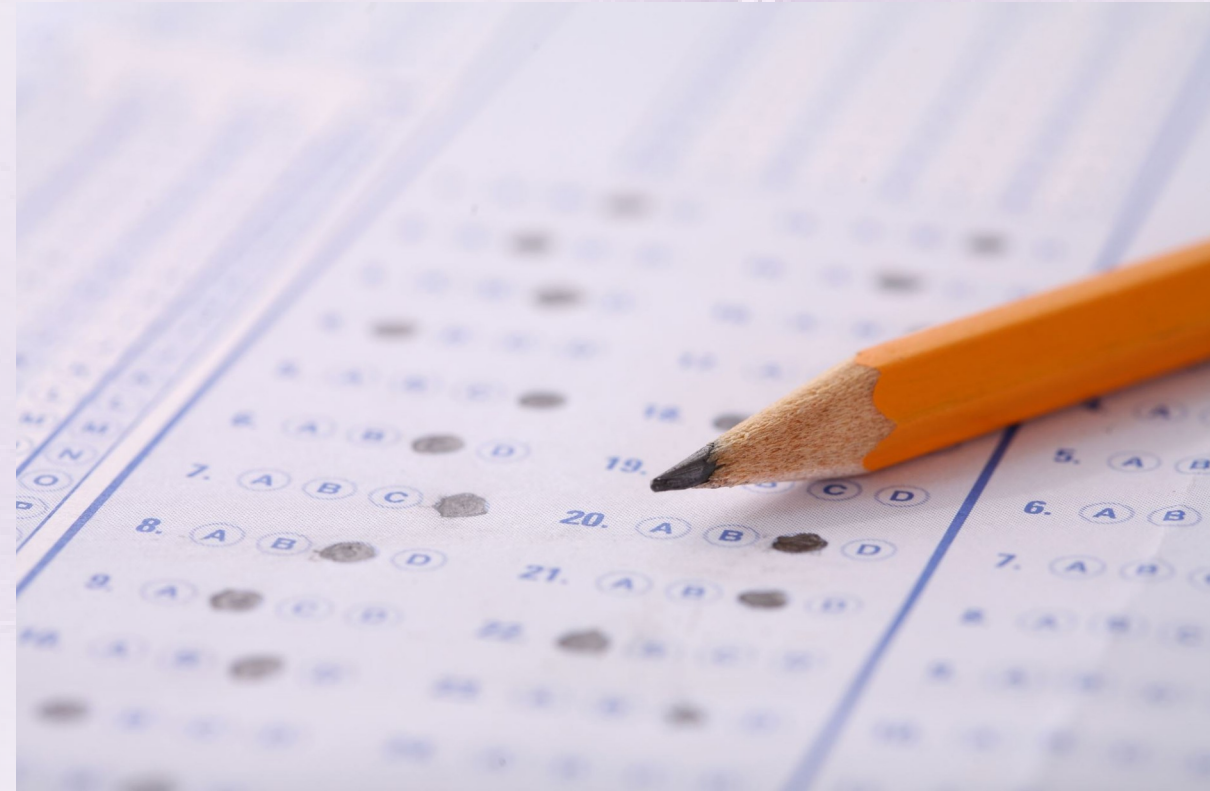
- Facilitates coordination among diverse stakeholders

Develops pan-European guidelines and incident coordination support

- Issues direction during major cyber crises

Example: ENISA's response in continent-wide ransomware

- Rapid guidance and information sharing enabled



EBA – Supervising the Financial Sector's Digital Integrity

EBA develops regulatory standards for financial institutions

- Standards guide ICT risk management requirements

Covers banks and certain financial institutions in the EU

- Obligations apply to technical and notification aspects

EBA standards shape technical response and reporting after breaches

- Transparency with regulators and customers mandatory

Example: Bank data breach reporting aligned with EBA standards

- Timely and transparent notifications required



ESMA – Guardian of Securities and Markets

ESMA ensures market transparency and cybersecurity controls

- Oversees trading venues, asset managers, intermediaries

Mandates incident disclosure affecting market integrity

- Requires robust response to security events

Example: Trading platform under ESMA requirements after attack

- Contains threat, resumes operations, communicates status

ESMA rules dictate communication with authorities and clients

- Ensures information flow during incidents





EIOPA – Oversight of Insurers and Pensions

EIOPA oversees insurers and pension providers' cyber risks

- Ensures management of internal and external cyber risk exposures

Focuses on digital infrastructure's importance for insurance products

- Monitors cyber insurance underwriting and risk modelling

Requires assessment and reporting of significant incidents

- Scrutinizes exposure and incident handling by providers

EIOPA drives standards for risk modeling and assessment

- Guides increasing cyber insurance adoption

National NIS2 Authorities and Implementation

National NIS2 authorities enforce cybersecurity rules in each EU country

- Responsible for NIS2 compliance within jurisdictions

Compare ENISA/ESAs as architects; national bodies as inspectors

- Local authorities ensure proper regulatory implementation

Coverage includes hospitals, energy, cloud services under NIS2

- Mandated security measures and reporting enforced

Ensure incident reporting through prescribed local channels

- Oversee implementation by relevant national organizations



Practical Scenario: Authority Relevance and Reporting

Fintech companies may fall under EBA, ESMA, EIOPA, NIS2 authorities

- Activities determine which regulatory umbrellas apply

Insurance products add EIOPA oversight to fintech obligations

- NIS2 applies if services are deemed essential/important

ENISA shapes but does not supervise individual companies directly

- Its guidance impacts standards enforced locally

Determining authority relevance is the first compliance step

- Activity mapping vital for reporting landscape navigation



Reporting Channels and Requirements

Incident reporting may involve NIS2 authorities and financial supervisors

- Multiple channels may require simultaneous notifications

Each authority may request different details and timelines

- Follow specific formats and escalation procedures

Example: Notify central bank and NIS2 authority if impacted

- Tailor communications to sector and national mandates

Preparedness and clarity are essential for regulatory reporting

- Timely, complete reports prevent compliance pitfalls



Managing Layered Reporting and Potential Tensions

Reporting structure can create confusion or tension

- Incidents may trigger obligations to more than one authority

Gray areas arise when incidents impact multiple systems

- Example: IT outage affecting trading and customer portals

Internal protocols needed to map obligations by incident type

- Ensure consistency across reporting channels

Regulatory relationships require transparency and trust

- Build through clear, timely communication practices

Organizational Structures for Incident Management

Assign clear responsibility for incident detection and escalation

- Coordination needed between legal, IT, and compliance teams

Fragmented approaches risk missed deadlines, incomplete notifications

- May result in regulatory penalties

Cross-functional training and playbooks enhance coordination

- Proactive engagement improves resilience and accountability

Regulatory relationships benefit from proactive collaboration

- Demonstrate resilience to stakeholders through preparation



Analogy – The Supervisory Ecosystem as a Symphony

Ecosystem authorities compared to orchestra sections

- ENISA, EBA, ESMA, EIOPA, NIS2 = string, wind, brass, percussion

Coordination needed to achieve regulatory harmony

- Adherence to common score enables effective collaboration

Organizations must anticipate cues, play roles with precision

- Accurate protocols avoid discord, penalties, and setbacks

Disharmony risks reputational damage, loss of trust, and penalties

- Coordination prevents operational failures and compliance issues



Cross-sector Coordination – Log4Shell Example

Log4Shell response demonstrated value of cross-sector coordination

- Rapid mobilization by authorities across Europe

ENISA issued advisories and intelligence during crisis

- Shared timely guidance with critical stakeholders

EBA, financial supervisors ensured banks' remediation underway

- Checked risk assessments and patching progress

NIS2 authorities coordinated critical infrastructure responses

- Collective response mitigated overall impact



Coordination Challenges in Supervisory Implementation

National differences can complicate regulatory compliance

- Varying interpretations of “significant incidents” exist

Overlapping mandates create compliance complexity for organizations

- Multiplicity of reporting requirements possible

Cloud providers face different thresholds in EU member states

- Security expectations depend on local NIS2 authority views

Deep understanding of EU and local practices required

- Organizations must align with multi-level standards

Strategies for Navigating Regulatory Complexity

Appoint regulatory liaison officers for dialogue and tracking

- Officers serve as primary contacts during incidents

Participate in industry groups and monitor regulatory changes

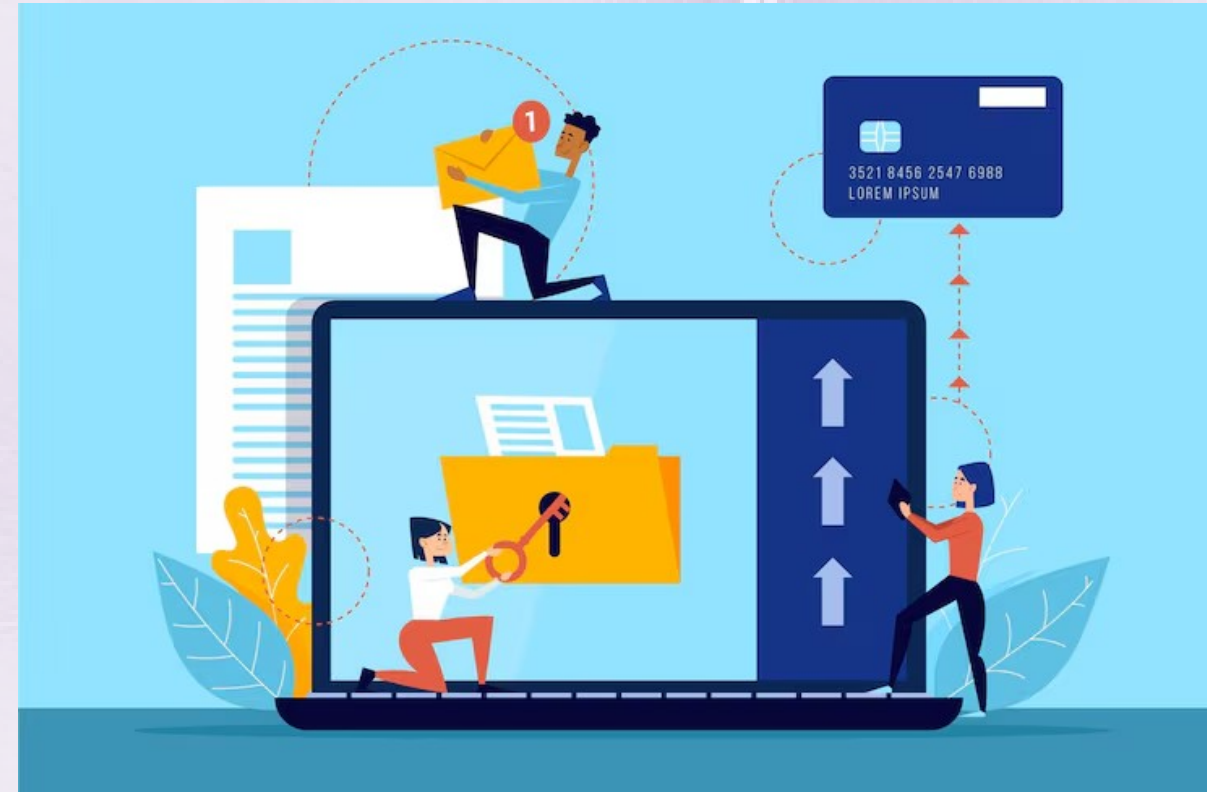
- Stay updated on evolving requirements

Invest in regulatory technology for mapping and reporting

- Tools automate deadlines and authority-specific reports

Strategies ensure compliance with varied obligations

- Systematic approach reduces manual errors



The Human Dimension of Compliance

Compliance reflects organizational culture and leadership

- Not only about checklists or documentation

Executive support for transparency and training is essential

- Staff better recognize and escalate incidents promptly

Proactive organizational posture builds trust externally

- Regulators, customers, partners value genuine engagement

Compliance culture satisfies regulators and empowers employees

- Drives resilience and continual improvement



Consequences of Non-compliance

Failure to report incidents leads to fines and scrutiny

- Penalties extend beyond monetary consequences

Consequences include regulatory penalties and loss of confidence

- Results may include investor loss and customer attrition

Incomplete notifications can prompt public and regulatory action

- May result in executive turnover or reputational damage

Technical readiness and alignment are both essential

- Both are needed to avoid regulatory fallout



Benefits from Proactive Regulatory Engagement

Regulatory engagement can serve as a competitive advantage

- Participation in pilot programs influences standards

Sharing incident data helps foster industry reputation

- Contributes to developing new policy and practice

Collaboration enhances compliance and drives innovation

- Improves resilience across sectors

Industry leaders shape policy by sharing best practices

- Reputational gains extend beyond compliance

Reflecting on Regulatory Relationships

Consider organization's approach toward regulators and compliance

- Is compliance viewed as burden or opportunity?

Identify channels and partnerships to strengthen

- Evaluate both formal and informal connections

Learn from successes and setbacks in regulatory engagement

- Reflect for organizational improvement and resilience

Build cross-functional partnerships to optimize compliance

- Apply lessons for future regulatory navigation



Summary of the Supervisory Framework

EU framework anchored by ENISA, EBA, ESMA, EIOPA, NIS2 authorities

- Each plays a distinct but interconnected role

Supervisory bodies shape standards and coordinate incident responses

- Standards impact risk management and rules enforcement

Identifying authorities and reporting is operational risk management

- Stakeholder trust depends on regulatory clarity

Knowledge of the ecosystem is critical for resilience and compliance

- Empowers organizations to navigate complexity effectively



Mastering Supervisory Interplay for Organizational Success

Mastering authority interplay equips professionals to safeguard organizations

- Enables effective incident response and digital economy resilience

Knowledge empowers navigation of regulatory complexity

- Anticipate expectations and continual improvement

Fostering transparency supports culture and stakeholder trust

- Organization readiness signals accountability

Continual learning strengthens operational and regulatory toolkit

- Promotes organizational excellence over time